



ISC 互联网安全大会



360 互联网安全中心

基于深度学习的SSL/TLS证书验证程序的自动化测试

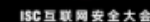
Deep Learning-based Automated Testing of Certificate Verification in SSL/TLS Implementations

陈超

山东大学网络与信息安全研究所成员

ISC 互联网安全大会
2018 Internet Security Conference

中国·北京
China · Beijing



实验

ZERO-TRUST SECURITY

WEB INTERNET

INFORMATION LEAK

TERMINAL AGE

TECHNOLOGY

PERSONAL PRIVACY IDENTITY SECURITY

IDENTITY

AUTHENTICATION

ISC 互联网安全大会

2018 Internet Security Conference

中国 · 北京

China · Beijing

INDUSTRIAL AUTOMATION

背景



ISC 互联网安全大会



360 互联网安全中心

 安全 | <https://www.baidu.com>

HTTPS = SSL/TLS + HTTP



身份验证
= 证书有效!!
保密性
完整性



ZERO-TRUST SECURITY

网络通信安全 = SSL/TLS

ISC 互联网安全大会 | 中国·北京
2018 Internet Security Conference | China · Beijing

什么是证书？

-----BEGIN CERTIFICATE-----

MIIEOzCCA6SgAwIBAgISESHzPTkKg5YmQA
9zgj5zezCYMA0GCSqGSIb3DQEBBQUAMIG9
MSkwJwYDVQQFEyBmRkhxOGItaXRhenRHY
URhT1BwNGFSUnViUk9xcGRXZzETMBEGA1
UECxMKR1QyMzc1MDkxNjExMC8GA1UEC
xMoU2VlIHd3dy5yYXBpZHNzbC5j

.....

HSMEGDAWgBSWrfqwW7mDZCp2whyKadp
C3P79KDANBqkqhkiG9w0BAQUFAAOBgQA
Owxx8TYeDFyuXy7aWTxo3KKk584IvcUKKg
fViTunuc4aF+gAR7eVwM3qSxnFjV6OvakjI7NU
7JOVs9zF/KWo/FwN8gz6/bkCCu4iHq/08T6Ob
oPAW/69NbXSSDezJuToGiaP2czu0czuIraadT+
mrtQLsyZJA0L1plwmgDZ9pLQ==

-----END CERTIFICATE-----



Version
Serial Number
Signature Algorithm Identifier
Issuer Name
Validity Period
Subject Name
Public Key Information
Issuer Unique ID
Subject Unique ID
Extensions

背景



ISC 互联网安全大会



360 互联网安全中心

现有许多开源的程序帮助你做复杂的证书校验过程



SSL/TLS 协议的实现程序说 “该证书有效” == 该证书有效?

ZERO-TRUST SECURITY

SSL/TLS协议的实现程序的来源：



ISC 互联网安全大会



360 互联网安全中心

证书校验规则



规则文档



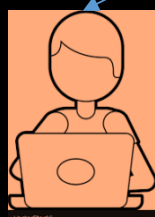
任何失误
都可能
引入安全风险



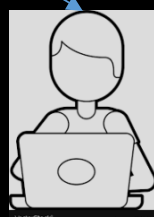
编码



编码



编码



编码



编码



编码



...



WEB INTERNET
INFORMATION LEAK
TERMINAL
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 | 中国·北京
2018 Internet Security Conference | China · Beijing



ISC 互联网安全大会



360 互联网安全中心

Q: 怎么测试这些SSL/TLS 协议的实现程序的正确性呢?

A: 模糊测试 + 差分测试

Q: 怎么生成测试证书?

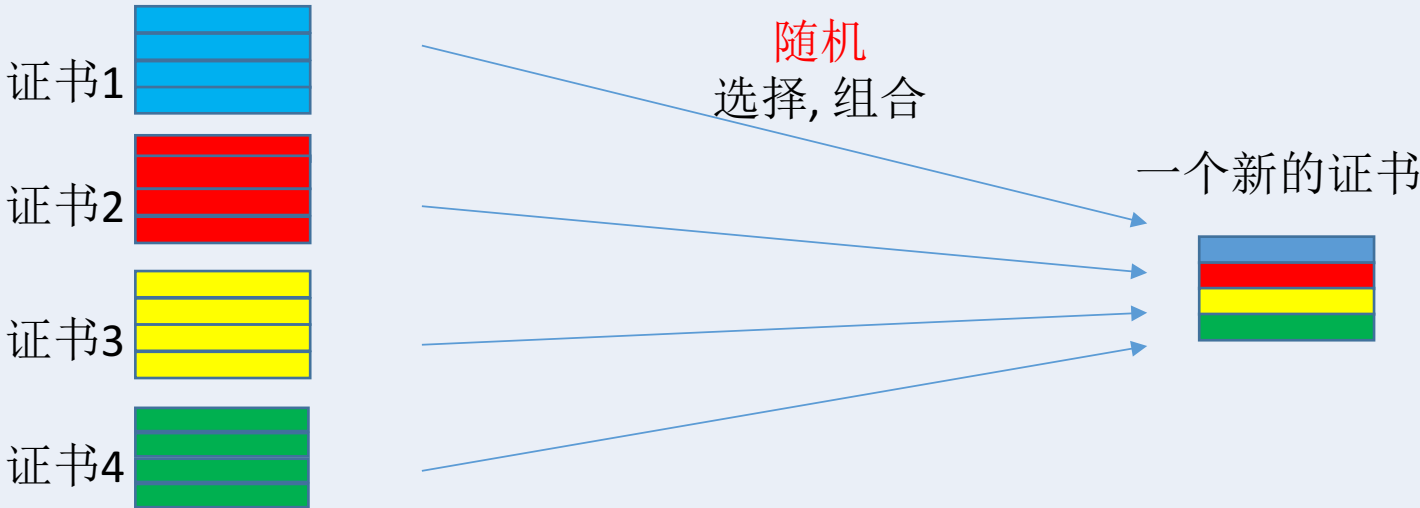
ZERO-TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TECHNOLOGY
TERMINAL AGE
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
2018 Internet Security Conference China · Beijing
INDUSTRIAL AUTOMATION

相关工作

Frankencert (S&P 2014) ([Chad Brubaker et al.](#))

Using Frankencerts for Automated Adversarial Testing of Certificate Validation in SSL/TLS Implementation



Mucert (FSE/ESEC 2015) ([Yuting Chen et al.](#))

Guided Differential Testing of Certificate Validation in SSL/TLS Implementations



解决的问题



ISC 互联网安全大会



360 互联网安全中心

太多的随机性

怎么减少、消除？

引入深度学习方法

ZERO-TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TECHNOLOGY
TERMINAL AGE
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
2018 Internet Security Conference China · Beijing
INDUSTRIAL AUTOMATION

我们的工作



ISC 互联网安全大会



360 互联网安全中心

新的框架.

我们提出了DRLgencert，第一个将深度学习应用于SSL / TLS证书验证模块的自动化测试框架.

新的技术.

我们为X.509证书设计了新的特征提取方法，更多的证书内容修改操作

框架实现及实验发现.

我们使用了多个广泛使用的SSL/TLS协议的现实程序，对DRLgencert进行了实验评估。实验结果分析表明DRLgencert是有效；使用深度学习来指导证书的变异是可行的

ZERO-TRUST SECURITY

ISC 互联网安全大会 | 中国·北京
2018 Internet Security Conference | China · Beijing

系统设计



ISC 互联网安全大会



360 互联网安全中心

ZERO-TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TECHNOLOGY
TERMINAL AGE
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
2018 Internet Security Conference China · Beijing
INDUSTRIAL AUTOMATION

系统概述



测试报告



证书库

ZERO-TRUST SECURITY

模糊
测试

差分测试



Open
SSL

arm
MBED



证书

深度
强化学习



互联网安全中心

	GnuT LS	Matri xSSL	Mbe dTLS	NSS	Open SSL	Wolf SSL	校验 结果
测试 证书	-2	-2	-4	-7	1	-10	

差分测试

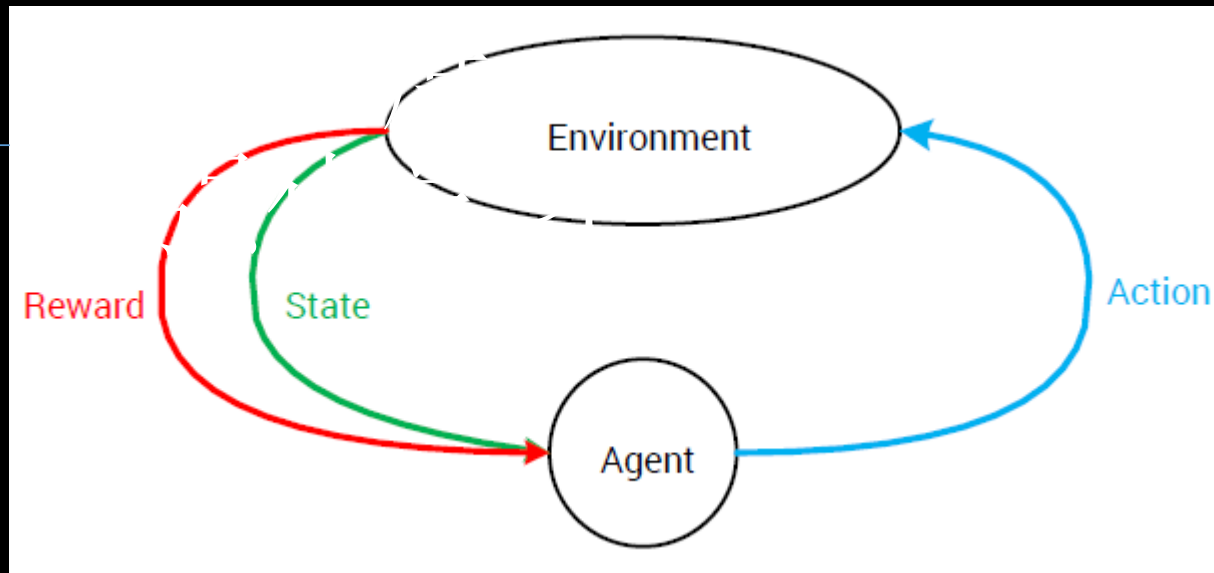


ISC 互联网安全大会



360 互联网安全中心

Version
Serial Number
Signature Algorithm Identifier
Issuer Name
Validity Period
Subject Name
Public Key Information
Issuer Unique ID
Subject Unique ID
Extensions



ZERO-TRUS

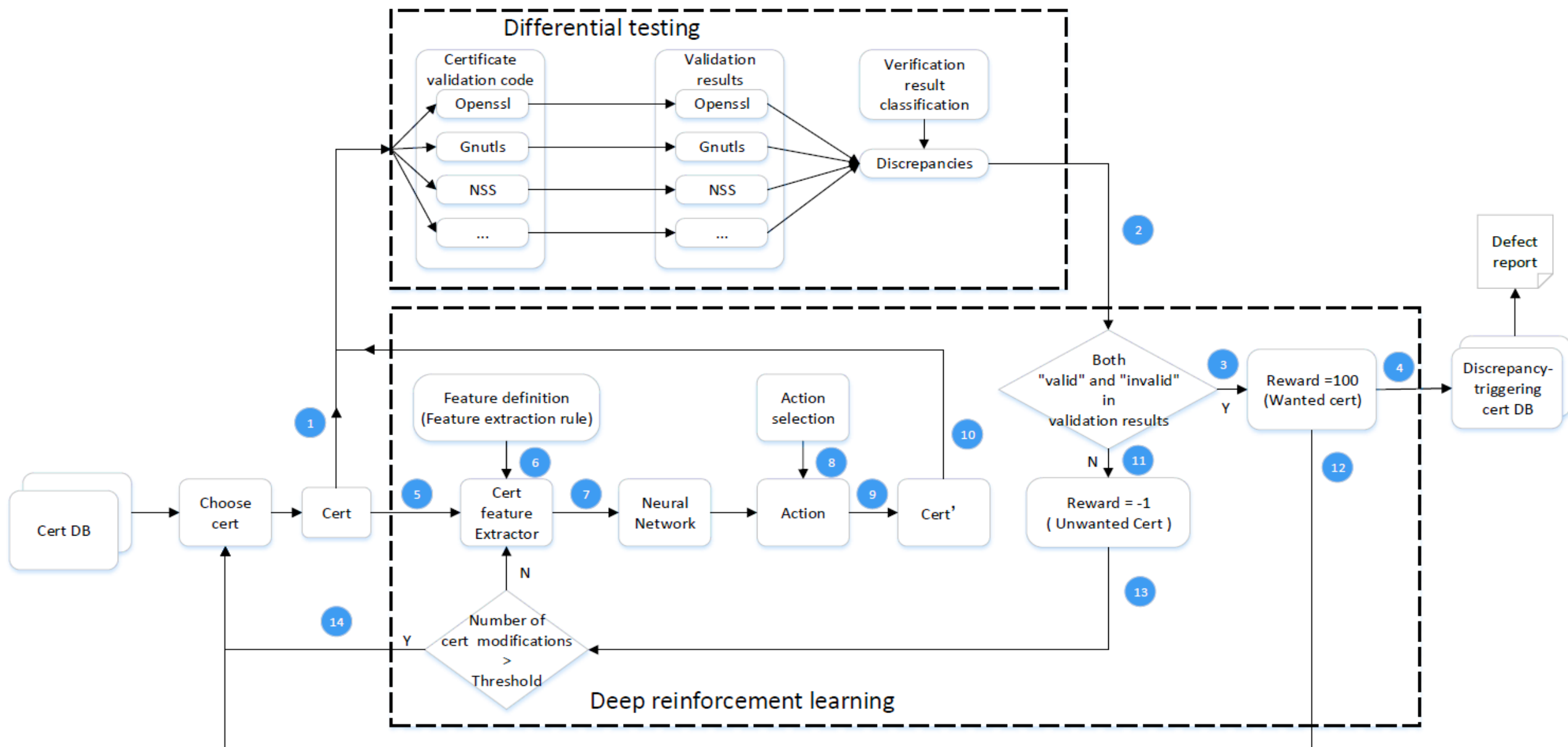
系统流程



ISC 互联网安全大会



360 互联网安全中心



实验



测试了6个SSL/TLS 协议的实现程序



收集了181,900个证书

生成了181,900个新的证书

84,661 个新证书能触发差分测试验证结果异常

总共发现23项代码实现缺陷

ZERO-TRUST SECURITY

差分测试结果示例



ISC 互联网安全大会



北京互联网安全中心

Sequence number	GnuTLS	MatrixSSL	MbedTLS	NSS	OpenSSL	wolfSSL	Sequence number	GnuTLS	MatrixSSL	MbedTLS	NSS	OpenSSL	wolfSSL
1	1	-14	-6	1	1	1	32	-3	-14	-6	-1	-1	1
2	-1	-14	-6	-4	-1	1	32	-3	-14	-6	-1	-1	1
3	1	-15	-6	1	1	1	34	1	-15	-3	-4	1	-4
4	-1	-15	-3	1	-1	-4	35	1	-10	-3	-4	-10	-13
5	-3	-15	-3	1	1	-4	36	1	-14	-3	1	-1	-4
6	-3	-15	-3	-4	1	-4	37	1	-15	-3	1	-10	1
7	-1	-15	-3	-10	-1	1	38	1	-14	-3	1	1	-13
8	-3	-14	-3	-4	-1	1	39	-3	-15	-6	-4	-1	1
9	-3	-15	-3	-4	-1	1	40	-3	-14	-6	1	1	-13
10	1	-14	-6	-4	-1	1	41	1	-15	-6	-8	1	-13
11	-14	-14	-6	-1	-1	1	42	1	-8	-3	-4	-1	-4
12	1	-15	-3	-8	1	-4	43	-3	-15	-6	1	1	-13
13	-3	-14	-6	1	1	1	44	1	-14	-3	-4	-1	-4
14	-3	-15	-3	-1	-1	1	45	-1	-15	-6	-1	-1	1
15	-1	-8	-6	-4	-1	1	46	1	-15	-3	-8	-10	-13
16	-1	-15	-3	1	-1	-13	47	1	-15	-6	-4	1	1
17	-1	-15	-3	-1	-1	1	48	1	-10	-6	1	1	-13
18	1	-14	-3	1	1	-4	49	1	-10	-3	-10	-10	-13
19	1	-15	-6	-4	1	-13	50	1	-15	-3	-4	-10	-13
20	1	-14	-6	1	-1	1	51	1	-15	-3	1	1	-13
21	-3	-15	-6	-4	1	1	52	1	-15	-3	-10	-10	1
22	1	-14	-3	-4	1	-4	53	1	-10	-3	1	-10	-13
23	-3	-15	-6	-1	-1	1	54	-1	-15	-3	-4	-1	1
24	-3	-15	-6	1	1	1	55	1	-14	-6	1	1	-13
25	1	-15	-3	1	1	-4	56	-1	-8	-6	-1	-1	1
26	1	-14	-3	1	1	1	57	-14	-15	-3	1	1	-4
27	1	-15	-3	-4	1	-13	58	1	-15	-6	1	-1	1
28	-1	-15	-6	-4	-1	1	59	-3	-15	-3	-4	-10	1
29	1	-10	-6	-4	1	-13	60	1	-15	-3	-8	1	-13
30	1	-15	-6	1	1	-13	61	-1	-14	-6	-1	-1	1
31	-1	-14	-3	-4	-1	1							

23项不当的证书验证代码实现



ISC 互联网安全大会



360 互联网安全中心

Flaw Type	GnuTLS	MatrixSSL	MbedTLS	NSS	OpenSSL	wolfSSL
Incorrect checking of time		2	1			
Incorrect checking of v1/v2 with X.509 v3 extension	1	1		1	1	
Incorrect checking of v1/v2 intermediate certificate	1	1		1	1	
Incorrect checking of version	1			1	1	1
Incorrect checking of serial number	1			1	1	
Inappropriate error report	1	1		1	1	1
Total	5	5	1	5	5	2

ZERO-TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TECHNOLOGY
TERMINAL AGE
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
2018 Internet Security Conference China · Beijing
INDUSTRIAL AUTOMATION

示例



ISC 互联网安全大会



360 互联网安全中心

MatrixSSL中有关有效期校验的代码片段

```
1 if (psBrokenDownTimeCmp(&beforeTime, &  
2 timeNowLinger) > 0)  
3 {  
4 /* beforeTime is in future. */  
5 cert->authFailFlags |=  
6 PS_CERT_AUTH_FAIL_DATE_FLAG;  
7 }  
8 else if (psBrokenDownTimeCmp(&timeNow, &  
9 afterTimeLinger) > 0)  
10 {  
11 /* afterTime is in past. */  
12 cert->authFailFlags |=  
13 PS_CERT_AUTH_FAIL_DATE_FLAG;  
14 }
```

```
1 /* The default value of allowed mismatch in times  
2 in X.509 messages and the local clock. The  
3 default value of 24 hours is mostly  
4 equivalent to old MatrixSSL behavior of  
5 ignoring hours, minutes and seconds in X.509  
6 date comparison. */  
7 #define PS_X509_TIME_LINGER (24 * 60 * 60)  
8 ...  
9 memcpy(&timeNowLinger, &timeNow, sizeof  
10 timeNowLinger);  
11 err = psBrokenDownTimeAdd(&timeNowLinger,  
12 PS_X509_TIME_LINGER);
```

ZERO-TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
2018 Internet Security Conference China · Beijing
INDUSTRIAL AUTOMATION



ISC 互联网安全大会



360 互联网安全中心

THANKS

ISC 互联网安全大会 | 中国·北京
2018 Internet Security Conference | China · Beijing